

PARA O ALTO E AVANTE

SECURITY INFORMATION AND EVENT MANAGEMENT (SIEM)



10

LISTA DE FIGURAS

Figura 1 – Funcionamento do syslog	5
Figura 2 – SOC IBM X-Force	16
Figura 3 – Funções do SOC.....	17
Figura 4 – Módulos SIEM	22
Figura 5 – Quadrante Mágico para soluções SIEM	24
Figura 6 – IBM QRadar	25
Figura 7 – Splunk Enterprise Security	26
Figura 8 – FortiSIEM	27

EMANIP

SUMÁRIO

1 SECURITY INFORMATION AND EVENT MANAGEMENT (SIEM)	4
2 SYSLOG.....	5
2.1 Formato syslog.....	6
2.2 Segurança syslog.....	7
3 SECURITY INFORMATION AND EVENT MANAGEMENT (SIEM)	10
4 SECURITY OPERATIONS CENTER	15
5 CARACTERÍSTICAS.....	17
5.1 Intenção.....	17
5.2 Contexto.....	18
5.3 Problema.....	18
5.4 Estrutura de funcionamento	21
6 SOLUÇÕES DE MERCADO	23
CONCLUSÃO.....	27
REFERÊNCIAS.....	29

1 SECURITY INFORMATION AND EVENT MANAGEMENT (SIEM)

A quantidade de *logs* dos mais diversos sistemas e dispositivos tem exigido o uso de ferramentas automatizadas e centralizadas que ajudem a identificar incidentes de segurança e minimizar o impacto nas operações das organizações.

O padrão mais conhecido de *log* centralizado em software é o *syslog*, usado por muitos sistemas operacionais, softwares de segurança e aplicativos. Porém é um protocolo simples, desenvolvido quando a segurança do *log* não era uma grande preocupação, não oferecendo granularidade no tratamento de diferentes tipos de eventos. Além disso, por ter poucos campos de dados, pode ser muito difícil extrair o significado dos dados registrados para cada evento quando há várias fontes de *logs* gerando eventos.

Ao contrário das infraestruturas baseadas em *syslog*, que têm como base um único padrão, o *Security Information and Event Management System* (SIEM) usa vários formatos de fornecedores diferentes, o que permite aos eventos de segurança serem coletados, normalizados, armazenados e correlacionados, possibilitando uma rápida identificação e resposta aos incidentes.

A proteção de infraestruturas de TI corporativas contra os ataques cibernéticos está se tornando cada vez mais exigente. Na maioria das empresas de médio a grande porte, um Centro de Operações de Segurança, ou *Security Operations Center* (SOC), é estabelecido para obter uma visão ampla e centralizada da segurança de TI e permitir reações rápidas no caso de incidentes.

Uma pesquisa do SANS Institute, realizada em 2017, revelou que mais de 80% dos SOCs são suportados por um sistema SIEM. As soluções SIEM permitem a automação da detecção de incidentes e medidas reativas a fim de mitigar danos e/ou preservar evidências forenses. Esses sistemas coletam dados relevantes de segurança em um ponto central de maneira a obter uma visão holística da segurança de TI das organizações e análises históricas e correlacionadas das ameaças.

Os maiores benefícios que as ferramentas SIEM oferecem são identificação aprimorada e tempo de resposta por meio da agregação e normalização de dados (REBACK, 2020).

Nas próximas seções vamos apresentar com mais detalhes o protocolo syslog e as funcionalidades do SIEM.

2 SYSLOG

O syslog é um padrão criado pela IETF para a transmissão de mensagens de notificações de eventos em redes IP. Esse protocolo é simples: o *host* envia uma pequena mensagem de texto (com menos de 1024 bytes) para o servidor (conhecido como "syslogd", "serviço syslog" ou "servidor syslog"), geralmente usando a porta UDP 514 (Figura "Funcionamento do syslog").

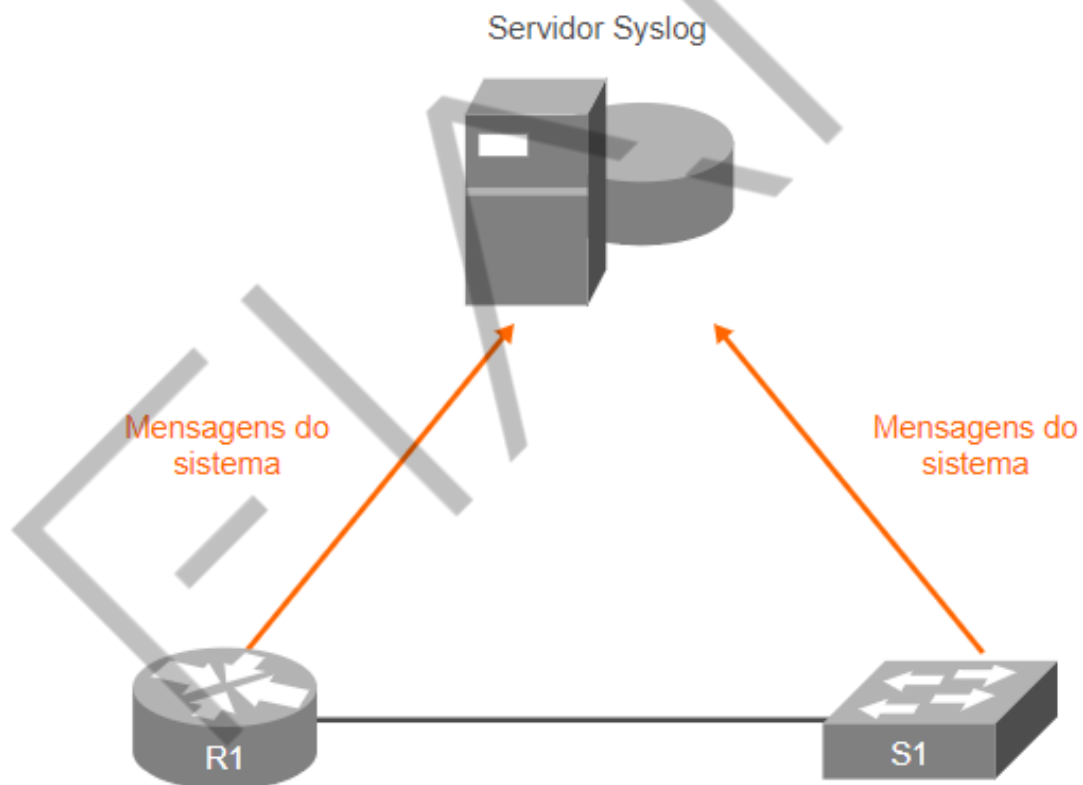


Figura 1 – Funcionamento do syslog
Fonte: Cisco (2013)

- Muitos dispositivos de rede como roteadores, switches, servidores de aplicativos, firewalls e outros oferecem suporte ao syslog. O protocolo syslog é tipicamente usado no gerenciamento de computadores e na auditoria de segurança de sistemas. Por ser suportado por uma grande

variedade de dispositivos em diversas plataformas, o protocolo pode ser usado para integrar diferentes sistemas em um único banco de dados.

- O protocolo syslog usa o mesmo formato para seus *logs* e o mesmo mecanismo básico para transferir suas entradas de *log* a um servidor syslog em execução em outro *host*. O syslog fornece uma estrutura simples para geração, armazenamento e transferência de entrada de *log*, que qualquer sistema operacional, software de segurança ou aplicativo pode usar se for projetado para isso. Muitos fornecedores utilizam o syslog como seu formato de registro nativo ou oferecem recursos que permitem a seus formatos de registro serem convertidos para formato syslog (NIST, 2006).

2.1 Formato syslog

O syslog atribui uma prioridade a cada mensagem com base na importância dos dois atributos a seguir:

- **Tipo de mensagem:** Conhecido como facilidade. Exemplos: mensagens do kernel do sistema operacional, mensagens do sistema de e-mail, mensagens de autorização, mensagens da impressora e mensagens de auditoria.
- **Gravidade:** Cada mensagem de registro tem um valor de gravidade atribuído, que vai de 0 (emergência) a 7 (depuração).

Como já mencionamos, o syslog é muito simples e cada mensagem do protocolo possui apenas três partes. A primeira parte especifica o recurso e a gravidade como valores numéricos. A segunda parte da mensagem contém um *timestamp* e o nome do host ou endereço IP da origem do log. A terceira parte é o conteúdo da mensagem. Nenhum campo padrão é definido no conteúdo da mensagem, pois o protocolo foi concebido para ser legível por humanos e não para análise de máquina. Isso fornece alta flexibilidade para geradores de log, que podem colocar qualquer informação que considerem importante no campo de conteúdo, mas torna a análise dos dados de registros bastante complexa e desafiadora.

Uma única fonte de dados pode usar diferentes formatos para registrar o conteúdo da mensagem, então um programa de análise precisaria estar familiarizado

com cada formato e ser capaz de extrair o significado dos dados dentro dos campos de cada formato. Esse problema se torna muito mais desafiador quando as mensagens de *log* são geradas por muitas fontes. Pode não ser viável entender o significado de todas essas mensagens, portanto a análise pode ser limitada a pesquisas de palavras-chave e padrões.

Algumas organizações projetam suas infraestruturas de syslog para que tipos semelhantes de mensagens sejam agrupados ou códigos semelhantes sejam atribuídos, tornando a automação da análise de *log* mais fácil de executar (NIST, 2006).

2.2 Segurança syslog

O syslog foi desenvolvido em uma época em que a segurança dos *logs* não era um elemento importante. Consequentemente, ele não possui controles básicos de segurança que preservariam a confidencialidade, a integridade e a disponibilidade de *logs*. Por exemplo, a maioria das implementações de syslog usa o protocolo UDP para transferir *logs* entre *hosts*.

UDP não oferece garantia de que as entradas de registro são recebidas com sucesso ou na sequência correta. Além disso, a maioria das implementações de syslog não executa nenhum controle de acesso, de modo que qualquer *host* pode enviar mensagens para um servidor syslog, a menos que outras medidas de segurança tenham sido implementadas para evitar isso, como a implementação de listas de controle de acesso (ACL) em dispositivos de rede para restringir quais *hosts* podem enviar mensagens ao servidor syslog.

Os invasores podem tirar vantagem disso inundando os servidores syslog com dados de registro falsos, que fazem com que entradas de registros importantes passem despercebidas ou mesmo causem uma negação de serviço (DoS). Outra deficiência da maioria das implementações de syslog é que elas não podem usar criptografia para proteger a integridade ou a confidencialidade dos *logs* em trânsito. Os invasores na rede podem monitorar, no syslog, mensagens contendo informações confidenciais sobre configurações do sistema e pontos fracos de segurança; invasores

também podem realizar ataques *man-in-the-middle* para modificar ou destruir mensagens em trânsito (NIST, 2006).

Como a segurança dos *logs* se tornou uma preocupação maior, várias implementações de syslog que foram criadas colocam ênfase maior na segurança. A maioria foi baseada em um padrão proposto, RFC3195, que foi projetado especificamente para melhorar a segurança do syslog. Implementações baseadas na RFC3195 podem oferecer suporte à confidencialidade, integridade e disponibilidade de *log* por meio de vários recursos, incluindo os seguintes:

- **Entrega confiável de log:** Várias implementações de syslog suportam o uso do protocolo TCP além de UDP. TCP é um protocolo orientado a conexão que garante a entrega confiável de informações por meio das redes. O uso do protocolo TCP para conexão entre o *host* e o servidor ajuda a garantir que as entradas de registro cheguem ao seu destino. Ter essa confiabilidade requer o uso de mais largura de banda da rede e normalmente leva mais tempo para as entradas de registro chegarem ao destino.
- **Proteção da confidencialidade da transmissão:** RFC3195 recomenda o uso do protocolo de transporte TLS para proteger a confidencialidade das mensagens syslog transmitidas. O TLS pode proteger as mensagens durante todo o trânsito entre os *hosts*. Ele só protege as cargas úteis de pacotes, não seus cabeçalhos de IP, o que significa que um observador na rede pode identificar a origem e o destino das mensagens syslog transmitidas, possivelmente revelando o IP dos servidores syslog e fontes de log. Algumas implementações de syslog usam outros meios para criptografar o tráfego de rede, como a passagem de mensagens syslog por túneis de *shell* seguro (SSH). A proteção de transmissões de syslog pode exigir largura de banda de rede adicional e aumentar o tempo necessário para que as entradas de registro cheguem ao destino.
- **Proteção e autenticação da integridade da transmissão:** RFC3195 recomenda que, se a proteção de integridade e a autenticação são desejadas, deve-se utilizar um algoritmo de resumo de mensagem.

Recomenda também o uso de MD5; revisões propostas para RFC3195 mencionam a utilização de SHA-1.

Algumas implementações de syslog oferecem recursos adicionais que não são baseados na RFC3195. Os recursos extras mais comuns são:

- **Filtragem robusta:** As implementações de syslog originais permitiram que as mensagens fossem tratadas de maneira diferente com base em suas instalações e prioridade, nenhuma filtragem mais refinada foi autorizada. Algumas implementações atuais de syslog oferecem recursos de filtragem mais robustos, como tratamento de mensagens de forma diferente com base no *host* ou no programa que gerou uma mensagem ou uma expressão regular correspondente no corpo de uma mensagem. Algumas implementações também permitem a aplicação de vários filtros em uma única mensagem, fornecendo recursos de filtragem mais complexos.
- **Análise de log:** Originalmente, os servidores syslog não realizavam nenhuma análise de dados de *log*, eles simplesmente forneciam uma estrutura para os dados de registro a serem registrados e transmitidos. Os administradores podem usar programas complementares separados para a análise de dados syslog. Algumas implementações de syslog têm recursos integrados de análise de *log* limitados, como a capacidade de correlacionar várias entradas de *log*.
- **Resposta ao evento:** Algumas implementações de syslog podem iniciar ações quando certos eventos são detectados. Exemplos de ações incluem o envio de traps SNMP, alertando os administradores por meio de páginas ou e-mails e lançando um programa ou script separado. Também é possível criar uma mensagem syslog indicando que um determinado evento foi detectado.
- **Formatos de mensagem alternativos:** Algumas implementações de syslog podem aceitar dados em não syslog, como traps SNMP. Isso pode ser útil para obter dados de eventos de segurança de *hosts* que não oferecem suporte a syslog e não podem ser modificados para isso.
- **Criptografia do arquivo de log:** Algumas implementações de syslog podem ser configuradas para criptografar o *log*, criando arquivos

automaticamente e protegendo sua confidencialidade. Isso também pode ser feito por meio do uso de SO ou de programas de criptografia de terceiros.

- **Armazenamento de banco de dados para logs:** Algumas implementações podem armazenar entradas de registro tanto em arquivos syslog como em banco de dados. Ter as entradas de log em um formato de banco de dados pode ser muito útil para a análise de *log* subsequente.
- **Limitação de taxa:** Algumas implementações podem limitar o número de mensagens syslog ou conexões TCP de uma fonte específica durante um determinado período. Isso é útil para prevenir uma negação de serviço para o servidor syslog e a perda de mensagens syslog de outras fontes. Essa técnica é projetada para causar a perda de mensagens de uma fonte e sobrecarregar o servidor syslog, podendo fazer com que alguns dados de registro sejam perdidos durante um evento adverso que gera um número excepcionalmente grande de mensagens.

Organizações que usam implementações de syslog com base no formato e na transferência de mensagens originais do protocolo devem considerar o uso de implementações syslog que ofereçam melhor proteção para a confidencialidade, integridade e disponibilidade. Muitas dessas implementações podem substituir diretamente o syslog existente. Ao avaliar substituições de syslog, as organizações devem prestar atenção especial à interoperabilidade, porque muitos clientes e servidores syslog oferecem recursos não especificados no RFC3195 ou outros esforços relacionados ao padrão. Além disso, organizações que utilizam informações de segurança e gerenciamento de eventos de software para armazenar ou analisar mensagens syslog devem garantir que seu ambiente (cliente/servidor) é totalmente compatível e interoperável com as informações de segurança e os eventos do software de gerenciamento.

3 SECURITY INFORMATION AND EVENT MANAGEMENT (SIEM)

O termo SIEM foi criado, em 2005, por Mark Nicolett e Amrit Williams do Gartner Group para descrever um produto capaz de coletar, analisar e apresentar informações

dos dispositivos de segurança de rede; softwares de controle de acesso; gerenciamento de vulnerabilidades; ferramentas de conformidade; *logs* de sistema operacional; banco de dados e aplicações; e, por último, dados de ameaças externas.

O sistema de Gerenciamento de Eventos e Informações de Segurança (SIEM) é relativamente novo se comparado ao syslog. A expressão SIEM é composta de dois termos: **Security Information Management** (SIM) e **Security Event Management** (SEM). Enquanto o SIM lida com gerenciamento centralizado, coleta, preservação de dados de registro histórico e geração de relatórios para conformidade, o SEM cobre gerenciamento de ameaças, monitoramento em tempo real de incidentes de segurança e acionamento adequado a reações em caso de incidente. Assim, os dados coletados são agregados para reduzir a quantidade de informações e facilitar o uso para reagir de maneira adequada a eventos de segurança.

Atualmente, o SIEM evoluiu para uma combinação dessas duas tecnologias de forma mais ampla e integrada, oferecendo soluções de segurança e combinando as vantagens do SIM e do SEM em um único sistema centralizado.

Em razão das inúmeras funcionalidades que um SIEM deve cumprir, uma definição acadêmica adequada é difícil de realizar. No entanto, o glossário de TI do Gartner Group nos ajuda com esta conceituação: “os sistemas SIEM coletam dados relevantes e conduzem análises históricas sobre eventos de segurança com uma ampla gama de diferentes tipos de eventos ou fontes de dados contextuais”. Além disso, ele suporta relatórios de conformidade e de investigação forense por meio da análise dos dados históricos armazenados nas mesmas fontes. A principal funcionalidade do SIEM é seu amplo escopo em fontes de eventos, bem como sua capacidade de correlacionar e analisar esses eventos em fontes heterogêneas.

O objetivo geral de coletar e analisar uma grande quantidade de dados em um local central é a identificação de anomalias e incidentes, que não seriam visíveis considerando os dados de um único sistema ou dispositivo. Além disso, facilita o monitoramento e o gerenciamento do estado de segurança de TI nas organizações.

Os SIEMs são essenciais para as organizações mitigarem ataques à sua infraestrutura de TI. Segundo a Fortinet (2021a), empresa de soluções de cibersegurança, um SOC, recebe em média 10 mil alertas por dia, e em grandes organizações, esse número pode chegar a mais de 150 mil alertas por dia, um número

expressivo para gerenciar com equipes de segurança enxutas. No entanto, o risco crescente representado por ameaças cibernéticas cada vez mais sofisticadas torna muito perigoso ignorar os alertas. Um único alerta pode significar a diferença entre detectar e impedir um grande incidente e perdê-lo totalmente. O uso do SIEM oferece uma forma mais eficiente de triagem e investigação de alertas pela equipe de segurança.

O SIEM intercepta registros de tantas fontes quanto possível, incluindo:

- Firewalls;
- Sistemas Unificados de Gerenciamento de Ameaças (*Unified Threat Management* – UTM);
- Sistemas de Detecção ou Prevenção de Intrusão (*Intrusion Detection System* – IDS, ou *Intrusion Prevention System* – IPS);
- Filtros de web (*webfilter*);
- Segurança de *endpoint*;
- Pontos de acesso sem fio (*access point*);
- Roteadores (*router*);
- *Switches*;
- Servidores de aplicativos.

Soluções SIEM podem coletar os mais diversos eventos para análise. A maioria utiliza agentes coletores que podem ser instalados nos diversos sistemas monitorados. Os agentes coletam eventos e os encaminham para um servidor central, que implementa técnicas para identificar anomalias, como análise estatística ou análises heurísticas desenvolvidas pelo próprio usuário. Como resultado de uma análise, ações podem ser configuradas a partir da interface de gerenciamento. (CERON, 2014).

Segundo o NIST (2006), a maioria dos produtos SIEM oferece suporte a duas formas de coleta de *logs*:

- **Sem agente:** O servidor SIEM recebe dados dos *hosts* de geração de log individuais sem necessidade de ter qualquer software especial instalado nesses *hosts*. Alguns servidores extraem *logs* dos *hosts*, o que geralmente

é feito solicitando ao servidor que se autentique em cada *host* e recupere seus logs regularmente. Em outros casos, os *hosts* enviam seus logs para o servidor, o que geralmente envolve cada *host* autenticar no servidor e transferir seus logs de maneira regular. Independentemente de os registros serem empurrados ou puxados, o servidor executa a filtragem de eventos, a agregação, a normalização e a análise nos logs coletados.

- **Com base em agente.** Um programa agente é instalado no *host* de geração de log para realizar a filtragem de eventos, agregação e normalização de logs para um tipo particular de log, então transmite o registro de dados normalizado para um servidor SIEM, geralmente em tempo real ou quase em tempo real, para análise e armazenamento. Se um *host* tiver vários tipos de registros de interesse, pode ser necessário instalar vários agentes. Alguns produtos SIEM também oferecem agentes para formatos genéricos, como syslog e SNMP. Um agente genérico é usado principalmente para obter dados de registros de uma fonte para a qual um agente específico de formato e um método sem agente não está disponível. Alguns produtos também permitem que os administradores criem agentes personalizados para lidar com fontes de log não suportadas.

Existem vantagens e desvantagens em cada método. A principal vantagem do modelo **sem agente** para o **com agente** é que eles não precisam ser instalados, configurados e mantidos em cada *host* de registro. A desvantagem principal é a falta de filtragem e agregação no nível do *host* individual, o que pode causar quantidades significativamente maiores de dados a serem transferidos pelas redes, aumentando o tempo necessário para filtrar e analisar os logs. Outra desvantagem potencial do método **sem agente** é que o servidor SIEM pode precisar de credenciais para autenticação em cada *host* de log. Em alguns casos, apenas um dos dois métodos é viável; por exemplo, pode não haver maneira de coletar remotamente logs de um determinado *host* sem instalar um agente nele.

Os produtos SIEM geralmente incluem suporte para centenas de tipos de fontes de log, como sistemas operacionais, software de segurança, servidores de aplicativos (como servidores da web e servidores de e-mail) e até mesmo controle de segurança física como dispositivos de leitores de crachás (RFID). Para cada tipo de fonte de log compatível, exceto para formatos genéricos, como syslog, os produtos SIEM

normalmente sabem como categorizar os campos registrados mais importantes (por exemplo, o valor no campo 12 dos *logs* do aplicativo XYZ significa o endereço IP de origem). Isso melhora significativamente a normalização, análise e correlação dos dados de registro sobre os realizados pelo software com menos compreensão granular de fontes e formatos de *log* específicos.

Além disso, o software SIEM pode realizar eventos de redução, desconsiderando os campos de dados que não são significativos para a segurança do computador, potencialmente reduzindo a largura de banda da rede do software SIEM e o uso de armazenamento de dados.

Independentemente de como ele recebe os dados de log (por meio de agentes ou o método **sem agente**), um servidor SIEM analisa os dados de todas as fontes de *log*, correlaciona eventos entre as entradas de *log*, identifica e prioriza eventos significativos e inicia respostas aos eventos, se desejado. Os produtos SIEM geralmente incluem vários recursos para apoiar a equipe de monitoramento:

- **Interfaces gráficas de usuário (GUI)**, que são projetadas especificamente para auxiliar os analistas na identificação de problemas potenciais e revisão de todos os dados disponíveis relacionados a cada problema.
- **Uma base de conhecimento de segurança**, com informações sobre vulnerabilidades conhecidas, o significado provável de certas mensagens de log e outros dados técnicos; analistas de segurança podem personalizar o conhecimento da base conforme necessário.
- **Recursos de rastreamento e relatório de incidentes**, às vezes com recursos robustos de fluxo de trabalho.
- **Armazenamento e correlação de informações** de ativos (por exemplo, dar maior prioridade a um ataque que visa um SO vulnerável ou um *host* mais importante).

Não há padrões específicos para o SIEM, então cada produto SIEM armazena e transmite dados no formato que ele escolher. Segundo NIST (2006), soluções SIEM também costumam oferecer recursos para proteger a confidencialidade, integridade e disponibilidade dos dados de registro. Por exemplo, comunicações de rede entre agentes e os servidores SIEM normalmente ocorrem no protocolo TCP, de forma

confiável e criptografada. Além disso, os agentes e servidores SIEM podem precisar fornecer credenciais um ao outro e ser autenticados com sucesso antes de poderem transferir dados.

As quatro principais funções do SIEM são:

- **Consolidação de registro** – Registro centralizado em um servidor.
- **Correlação de ameaças** – A inteligência artificial usada para identificar invasores usando a classificação e a filtragem de vários registros/logs.
- **Gerenciamento de incidentes** – O fluxo de trabalho quando uma ameaça é identificada:
 - Notificação: por meio de alertas (e-mails, SMS);
 - Criação de ticket do problema;
 - Respostas automatizadas: execução de *scripts* (instrumentação);
 - Registro de resposta e correção.
- Apresentação de relatórios:
 - Eficiência e eficácia operacional;
 - Conformidade: SOX, HIPPA, FISMA etc.;
 - Investigações: *ad hoc* e forenses.

4 SECURITY OPERATIONS CENTER

O SIEM não é um software isolado que funciona intocado por um longo período. Na maioria dos casos, ele é incorporado a um *Security Operation Center* (SOC). Um SOC consiste basicamente em softwares, processos e uma equipe de analistas e especialistas em segurança com o objetivo de monitorar todos os eventos relevantes relacionados à segurança de uma infraestrutura de TI.

O software utilizado para coletar dados e arquivos de *log* de todos os ativos relevantes e para análises posteriores é um sistema SIEM. Após a detecção de um potencial incidente, a equipe do SOC determina as medidas a serem tomadas, como informar a equipe de resposta a incidentes ou as partes interessadas dos sistemas

afetados. Na maioria dos casos, os SOCs são organizados hierarquicamente em várias camadas, sendo que a camada mais baixa depende de uma grande quantidade de funcionários. Em grandes organizações, eles são organizados em vários turnos para serem capazes de reagir de maneira adequada a incidentes de segurança 24 horas por dia, 7 dias por semana (24x7). A IBM é uma empresa que mantém uma equipe especializada em respostas a incidentes conhecida como X-Force.

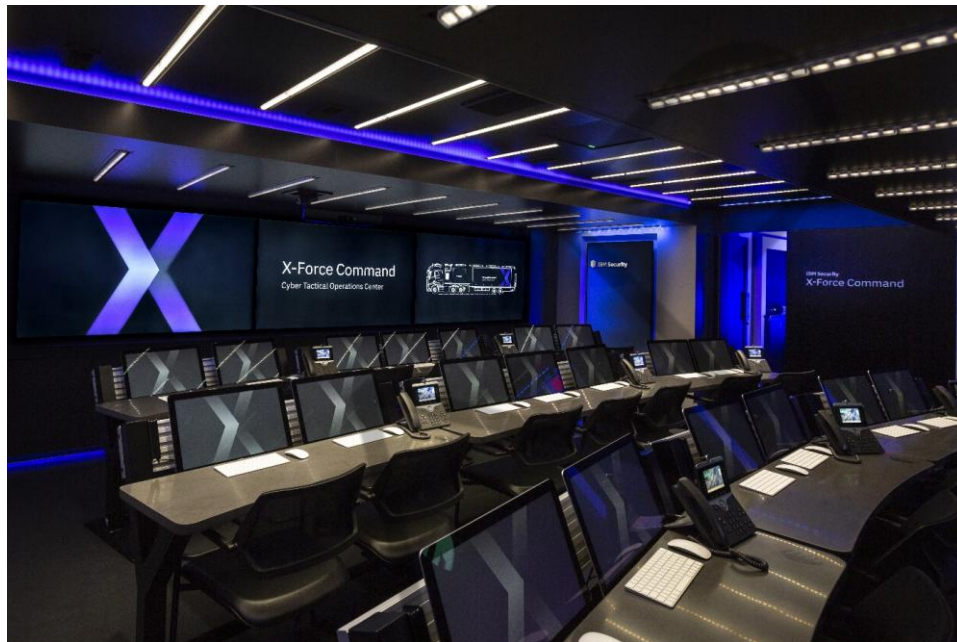


Figura 2 – SOC IBM X-Force
Fonte: IBM (2020)

Em razão da crescente quantidade de fontes diferentes de dados de log e outros eventos relevantes para a segurança, e a subsequente necessidade crescente de analistas de segurança bem treinados, a demanda por um nível mais alto de automação aumenta. Assim, o SIEM pode ajudar a analisar e reagir automaticamente a incidentes de segurança de maneira centralizada e ainda auxiliar analistas, visualizando melhor a grande quantidade de dados para alavancar mais e de maneira eficiente o conhecimento especializado dos analistas.

O SOC tem como objetivo aprimorar continuamente os esforços de segurança de uma organização, com a tarefa de rastrear, detectar, investigar e reagir a ameaças cibernéticas 24 horas por dia (CYBRHAWK, 2020).



Figura 3 – Funções do SOC
Fonte: CybrHawk (2020)

5 CARACTERÍSTICAS

O SIEM, também conhecido como sistema de análise de segurança ou ferramenta/sistema de inteligência contra ameaças cibernéticas, tem as seguintes características (VIELBERTH; PERNUL, 2018):

5.1 Intenção

Coleta de todos os dados relevantes de segurança em um ponto central para identificar ameaças ou incidentes. Portanto, fornece a oportunidade de lidar com diferentes formatos de dados e analisar os dados em tempo real e historicamente. Além disso, oferece a possibilidade de interagir com especialistas.

5.2 Contexto

Nas organizações, existem muitos sistemas diferentes e dispositivos de segurança que fazem parte das infraestruturas de TI. Na maioria dos casos, eles cresceram historicamente e, portanto, é difícil acompanhar o estado geral da segurança cibernética. Além disso, sistemas de segurança isolados, como firewalls, podem apenas detectar ou prevenir ataques muito específicos. Para obter uma visão ampla em relação à segurança, e descobrir ataques cibernéticos mais avançados, faz-se necessário um sistema centralizado coletando todas as informações de segurança relevantes. Portanto, a análise de ameaças em tempo real é essencial para o SOC ser capaz de reagir rapidamente.

5.3 Problema

A grande quantidade de dispositivos e softwares relevantes para a segurança dificulta a obtenção de uma visão ampla da segurança nas organizações. Especialmente os ataques sofisticados que afetam vários sistemas (comumente chamados de ameaças persistentes avançadas – ATP) e, muitas vezes, permanecem não detectados. Além disso, a enorme quantidade de logs gerados torna a situação ainda mais desafiadora, porque complica as análises relacionadas à segurança e torna mais difícil encontrar reações apropriadas em caso de incidente.

As forças associadas a esse problema são as seguintes:

- **Taxa de detecção e falsos positivos:** Diminuir a carga de trabalho manual de analistas e especialistas, detectando automaticamente incidentes e anomalias. A taxa falso positivo deve ser muito baixa para aliviar os membros da equipe de forma a analisarem corretamente o incidente detectado e decidir por mais passos. Além disso, a taxa de detecção deve ser a mais alta possível, para fornecer um elevado nível de segurança. Cada incidente que não foi detectado a tempo pode acabar causando mais horas de trabalho ou danos adicionais.
- **Tempo de descoberta e reação:** A ideia é ser capaz de detectar e reagir a um ataque o mais rápido possível, porque o tempo que uma empresa

precisa para detectar e reagir a um ataque impacta diretamente o dano financeiro (KASPERSKY LAB, 2016). A fim de mitigar as perdas, é importante reagir automaticamente a um incidente ou informar as pessoas certas a tempo para que executem um plano de contingência ou recuperação de desastres.

- **Usabilidade:** Precisamos de um sistema que seja fácil de usar por analistas e especialistas. A ação de conectar novos dispositivos e configurar a detecção de novos incidentes (por exemplo, criar regras de detecção) deve ser rápida e facilitada; além disso, o conhecimento especializado na ferramenta deve ser o mais baixo possível.
- **Preparação visual de dados e integração de conhecimentos especializados:** Não é fácil substituir especialistas que analisam os dados/logs manualmente com tanta rapidez, especialmente em casos de detecção automática de incidentes que nunca tenham ocorrido antes. Assim, a preparação visual dos dados e o enriquecimento com dados de contexto são muito importantes para integrar o conhecimento especializado de maneira ideal, não apenas no início e no fim do processo analítico, mas também no meio. Como resultado, por exemplo, informações difíceis de interpretar são transformadas em dados de inteligência mais úteis (por exemplo, endereços IP são traduzidos para a geolocalização de sua origem). Além disso, um alto nível de usabilidade permite que os especialistas trabalhem com eficiência.
- **Grau de automação:** Uma equipe bem treinada no domínio da segurança é bastante rara. No entanto, em grandes organizações os SOCs precisam ter uma equipe 24 horas. Implantar um sistema que ajude a reduzir o número de pessoas necessárias, automatizando certas etapas, pode ser benéfico para a mitigação de riscos à segurança e a redução de custos. A análise deve ser ainda mais automatizada e as reações precisam ser disparadas ou realizadas automaticamente, sempre que possível.
- **Número de dispositivos conectáveis:** A fim de fornecer uma visão ampla da segurança corporativa, com a exploração de todos os dados relevantes, todo dispositivo pertinente à segurança deve ser conectado. Isso apresenta

dois requisitos: primeiro, deve ser possível processar muitos dados de *log*; segundo, deve-se ser capaz de conectar quase todos os tipos de dispositivo ou o software. Portanto, o SIEM precisa ser capaz de lidar com muitos formatos de *logs* diferentes.

- **Análise:** Para ser capaz de detectar e identificar ataques, uma grande variedade de eventos e dados adicionais devem ser analisados. A possibilidade de criar regras ou outros mecanismos de detecção deve ser oferecida. O mecanismo de análise deve ser capaz de correlacionar vários eventos permitindo a detecção de incidentes ou ameaças. Desse modo, os recursos para análises automáticas, manuais ou com suporte humano devem ser oferecidos.
- **Reutilização e compartilhamento de inteligência:** Deve-se fornecer um elevado grau de reutilização, portanto o padrão deve ser dividido em diferentes módulos que sejam fáceis de trocar e integrar por outros sistemas semelhantes. Eles devem ser francamente acoplados e as interfaces devem ser definidas. Além disso, interfaces para compartilhar os resultados das análises com outras organizações devem ser fornecidas.
- **Custos:** Os custos desempenham um papel importante para todo sistema destinado à aplicação em uma empresa. Portanto, diminuir o tempo necessário para a implementação e reduzir a equipe necessária para executar e monitorar o software são fatores críticos de sucesso.

O SIEM também enfrenta algumas dificuldades, como:

- **Grande esforço para introdução:** Em razão da complexidade das infraestruturas de TI das organizações, integrar um SIEM exige muito esforço. Além disso, a heterogeneidade das demandas ao sistema dificulta a criação de uma solução padrão que seja utilizável por várias empresas.
- **Demanda por especialistas:** Embora a demanda por pessoal seja reduzida, ainda faltam informações de observações realizadas por humanos: o padrão usa apenas dados de registro e contexto gerados por máquinas. No entanto, os humanos também podem fornecer informações valiosas para um SIEM. Por exemplo, se um funcionário recebe um telefonema malicioso, que poderia ser o início de um ataque em grande

escala, ele não consegue alimentar o SIEM. Há a necessidade de especialistas para apresentar e monitorar o sistema.

5.4 Estrutura de funcionamento

A seguir, estudaremos a estrutura de um SIEM e como ele realiza o tratamento dos dados/logs. A estrutura pode ser dividida em oito componentes, conforme é possível observar na Figura “Módulos SIEM”. O primeiro módulo é responsável pela coleta de *log* e por fornecer os dados de *log* coletados para os módulos adicionais. Os dados de entrada podem ser fornecidos por várias fontes de *log*.

O componente de enriquecimento (2) usa dados de contexto para fornecer informações adicionais para dados de registros simples a fim de melhorar o processamento adicional fornecendo dados de *log* enriquecidos. Várias fontes de dados de contexto fornecem os dados necessários. Um exemplo de enriquecimento de dados de *log* é resolver o endereço IP para uma geolocalização que pode permitir a detecção de algumas ameaças específicas. Além disso, as ferramentas de descoberta de ativos fornecem informações sobre sistemas ou dados sensíveis que requerem mais proteção. Os dados da avaliação de vulnerabilidades podem ajudar a relacionar ameaças a fontes de dados específicas. Além disso, os dados enriquecidos são, na maioria dos casos, muito mais fáceis para um ser humano ler e interpretar.

Para habilitar e facilitar o processamento posterior, os dados são reestruturados em um formato padronizado (normalizando dados de registro) no componente de normalização (3). O componente de normalização é necessário, pois as diversas fontes de geração de *log* conectadas usam muitos formatos para armazenar e enviar *logs*. Além disso, várias tecnologias de armazenamento são aplicadas. Por exemplo, alguns sistemas utilizam bancos de dados relacionais e outros usam arquivos de texto simples ou tecnologias proprietárias como syslog. Assim, é necessário transformá-los em um único formato de registro uniforme. Além disso, é muito mais fácil para os especialistas criarem regras de detecção para formatos de *log* padronizados em etapas posteriores.

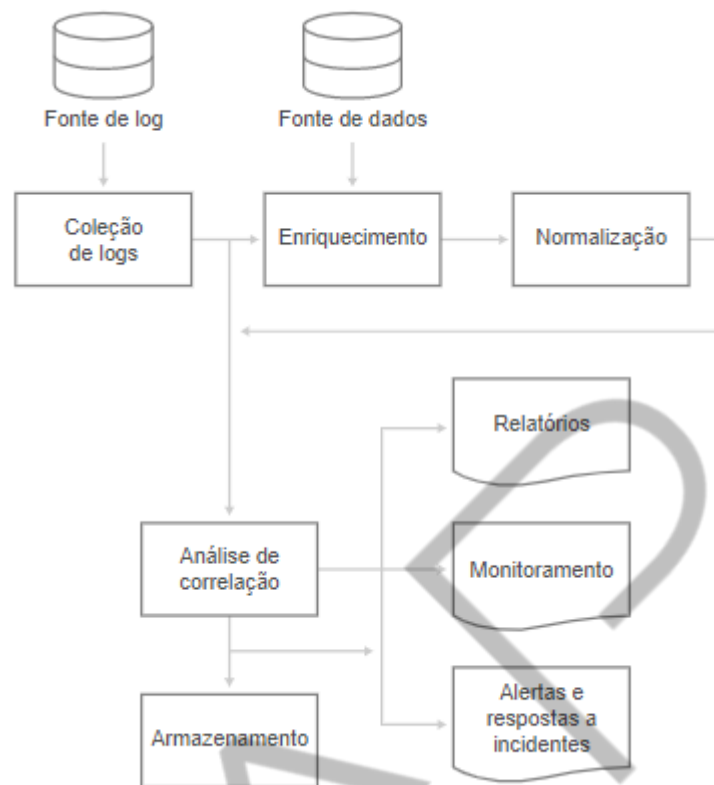


Figura 4 – Módulos SIEM
Fonte: Adaptado de Vielberth; Pernul (2018)

A parte principal é o componente de correlação e análise (4), pois é onde os incidentes são finalmente reconhecidos com base em dados de registro normalizados de entrada. Além disso, as análises são conduzidas com base em dados históricos fornecidos pelo componente de armazenamento (5). Os resultados da análise e os dados de registro brutos também são armazenados aqui. A fim de permitir o processamento posterior por outros módulos, os dados preparados são fornecidos.

A correlação e a análise são conduzidas em tempo real nos dados de registro normalizados (etapa 3) a fim de prover o reconhecimento de incidentes o mais rápido possível. Além disso, análises históricas são realizadas para fins forenses ou de modo a detectar incidentes esquecidos antes, por exemplo, o padrão de um ataque que ainda não era conhecido. Existe uma infinidade de diferentes métodos para correlacionar e analisar logs, no entanto, a abordagem mais comum e simples é detectar incidentes com base em regras. Essas regras podem ser derivadas automaticamente, criadas por analistas humanos ou recuperadas de outros sistemas ou organizações.

Finalmente, as descobertas podem ser relatadas ou compartilhadas com outros sistemas ou organizações na forma de inteligência de ameaças, no componente de

relatórios (6). No componente de monitoramento (7), incidentes não detectados automaticamente podem ser reconhecidos por analistas para a tomada de decisão sobre ameaças do tipo falso positivo. O componente de respostas (8) pode propagar alertas para as partes responsáveis interessadas ou reagir automaticamente no caso de um incidente.

6 SOLUÇÕES DE MERCADO

Existem diversas soluções de mercado para sistemas SIEM, dos mais diversos fornecedores. O Gartner Inc, uma empresa americana de consultoria e pesquisa, realiza estudos periódicos sobre soluções de tecnologia, dos mais diversos fornecedores, conhecido como Quadrante Mágico. O quadrante é uma representação gráfica do mercado escolhido num determinado período a fim de apoiar decisões de negócio. Ele divide os fornecedores em quatro quadrantes: líderes (*leaders*), desafiadores (*challengers*), visionários (*visionaries*) e concorrentes de nicho (*niche players*).

Na Figura “Quadrante Mágico para soluções SIEM”, podemos observar as soluções de SIEM consideradas líderes na edição de fevereiro de 2020: Splunk, IBM, Exabeam, Securinix, Rapid7, LogRhythm e Dell Technologies (RSA). Discorreremos sobre algumas delas.



Figura 5 – Quadrante Mágico para soluções SIEM

Fonte: Gartner (2020)

- **IBM QRadar:** É um sistema modular e, portanto, aplicável a empresas de médio a grande porte. Pode ser implantado como um sistema autônomo, em uma arquitetura distribuída ou na nuvem. O IBM QRadar Security Information and Event Management (SIEM) ajuda as equipes de segurança a detectar e priorizar com precisão ameaças em toda a empresa e fornece *insights* inteligentes que permitem às equipes responderem rapidamente para reduzir o impacto de incidentes. Ao consolidar eventos de log e dados de fluxo de rede de milhares de dispositivos, terminais e aplicativos distribuídos por toda a rede, o QRadar correlaciona todas essas informações diferentes e agrega eventos relacionados a alertas únicos para acelerar a análise e a correção de incidentes (IBM, 2018). A primeira camada do QRadar coleta *logs* (*Event Collectors*) e fluxos de dados (*QFlow Collector*) e os normaliza primeiro analisando e, em seguida, reestruturando os dados em um formato utilizável. A segunda camada enriquece os logs com dados adicionais de origens com o *QRadar Risk Manager*, que fornece um mapa da topologia de rede das organizações. O *QRadar Vulnerability Manager* identifica os riscos de segurança na rede e o *QRadar Custom*

Rules Engine analisa os dados de incidentes e ameaças. Depois que os dados são analisados, eles são gravados no armazenamento, enquanto o *QRadar Incident Forensics* fornece o histórico de investigação, com base nos dados brutos coletados. A camada de pesquisas de dados fornece interfaces para interação humana. Assim, relatórios podem ser criados e o usuário tem a possibilidade de procurar e analisar os dados coletados com a ajuda do *QRadar Console*. Além disso, os alertas são acionados e apresentados ou encaminhados para analistas.

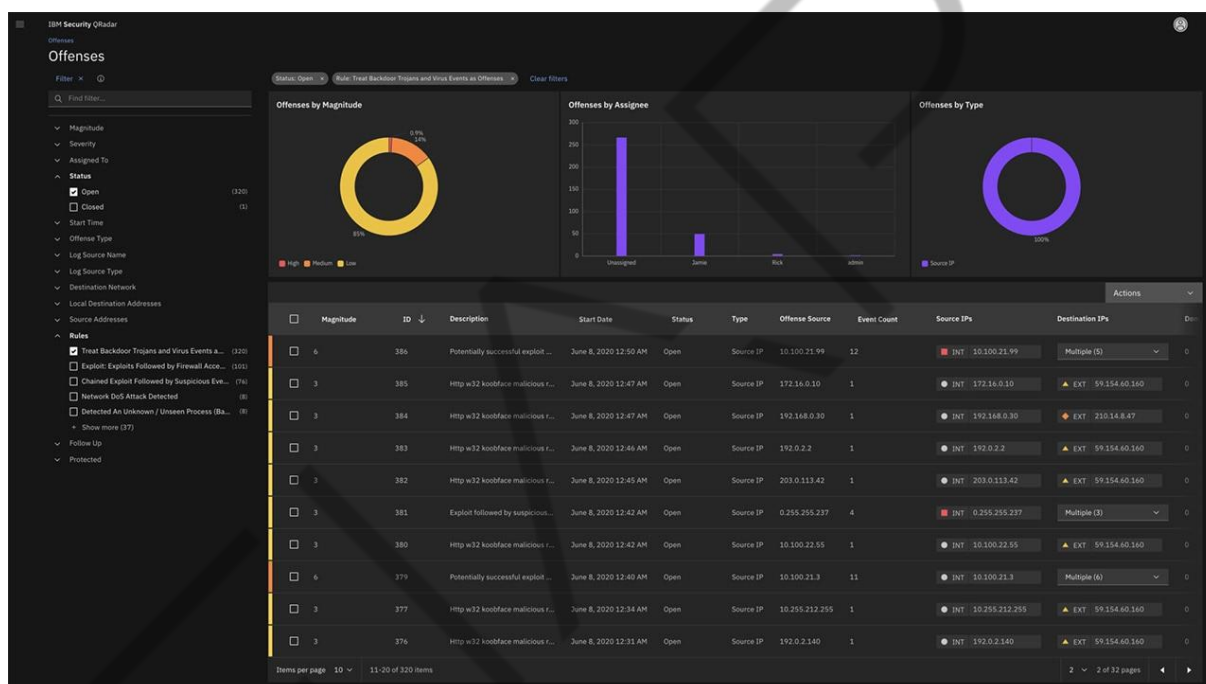


Figura 6 – IBM QRadar
Fonte: IBM (2020)

- **Splunk:** Splunk Enterprise é o núcleo de sua solução SIEM e fornece coleta e armazenamento de dados. Esses serviços podem ser estendidos com diferentes pacotes, que, por exemplo, abrangem recursos analíticos de comportamento do usuário. O Splunk transforma dados de máquina em inteligência operacional em tempo real e capacita as organizações para monitorar, pesquisar, analisar, visualizar e agir sobre os grandes fluxos de dados de computador gerados por sites, aplicativos, servidores, redes, dispositivos móveis e outros que alimentam o negócio (SPLUNK, 2021).

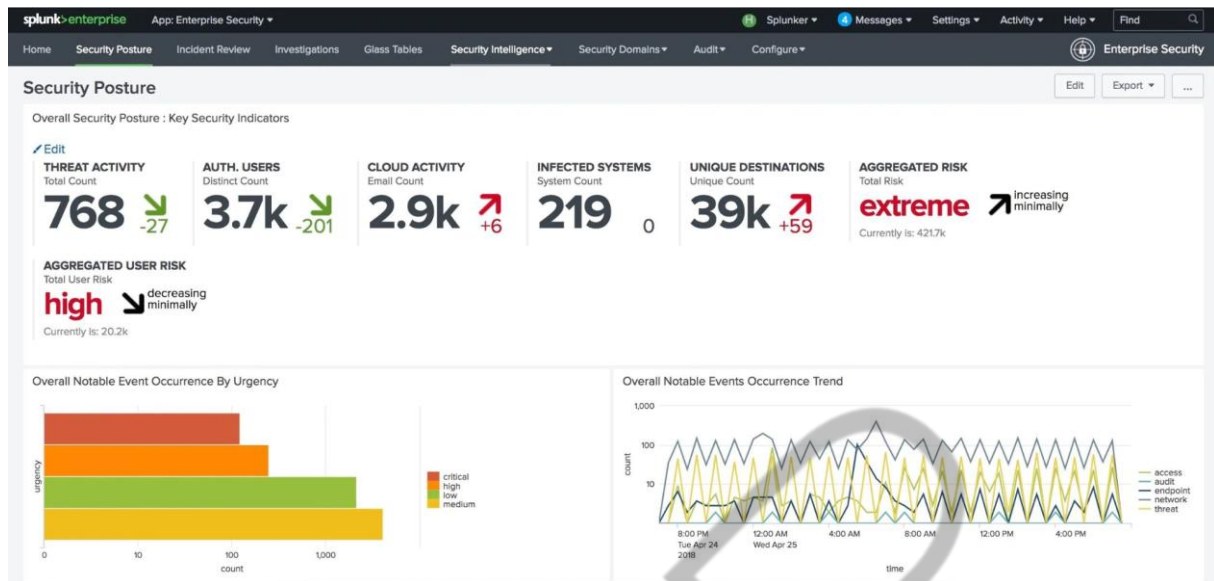


Figura 7 – Splunk Enterprise Security
Fonte: Splunk (2020)

- **LogRhythm:** O conjunto principal de recursos para uma solução SIEM inclui coleta de dados, análise (ou normalização) de dados e correlação desses dados para identificar atividades suspeitas ou problemáticas. Esse processamento e enriquecimento de dados permite todas as formas de análise de dados e pode ter um impacto direto na eficácia com que uma organização pode pesquisar e acessar seus dados. Depois que os dados são ingeridos e normalizados, o software SIEM correlaciona eventos em todos os dados em conjunto para identificar padrões de comprometimento e alertar o usuário final sobre atividades suspeitas (LOGRHYTHM, 2021).
- **FortiSIEM:** O FortiSIEM reúne visibilidade, correlação, resposta automática e remediação em uma única solução escalável. Ele reduz a complexidade do gerenciamento das operações de rede e segurança para efetivamente liberar recursos, melhorar a detecção de violação e até mesmo preveni-la. Além disso, sua arquitetura permite a coleta de dados unificada e análises de diversas fontes de informações, incluindo *logs*, métricas de desempenho, alertas de segurança e alterações de configuração. O FortiSIEM combina as análises tradicionalmente monitoradas em silos separados do centro de operações de segurança (SOC) e do centro de operações de rede (NOC) para uma visão mais holística da segurança e da disponibilidade dos negócios (FORTINET, 2021).



Figura 8 – FortiSIEM
Fonte: Fortinet (2020)

CONCLUSÃO

O SIEM é uma evolução do padrão de *logs* centralizados como o syslog, ao coletar dados de muitas fontes e formatos diferentes, correlacionando os eventos de segurança. Com a implementação de um Centro de Operações de Segurança (*Security Operation Center*), a equipe de analistas e especialistas em segurança conseguem monitorar de forma fácil (e gráfica) todos os eventos relevantes relacionados à segurança de redes, possibilitando uma rápida identificação e resposta a incidentes.

O desafio do SIEM, devido a enorme quantidade de *logs* gerados por diversos dispositivos e softwares, é de correlacionar os dados de *logs* de diferentes fontes e melhorar a análise e o tempo de resposta da equipe do SOC, com:

- Melhor usabilidade da ferramenta e uso de dados gráficos;
- Elevar o grau de automação da ferramenta, possibilitando respostas automáticas com o uso de inteligência artificial;
- Diminuir os falsos-positivos com uma melhor taxa de detecção;
- Integração de conhecimentos especializados, como uma base de vulnerabilidades conhecidas (CVE);

- Reutilização e compartilhamento de inteligência.

Com diversas soluções disponíveis no mercado, cabe às organizações adotarem para seus times de segurança o SIEM, considerando os custos envolvidos e o risco para o negócio.

EMSP

REFERÊNCIAS

AT&T BUSINESS. **AlienVault OSSIM**. 2021. Disponível em: <<https://cybersecurity.att.com/products/ossim>>. Acesso em: 12 jun. 2024.

CROWLEY, C. Future SOC: SANS 2017 Security Operations Center Survey. **SANS**, 2007. Disponível em: <<https://www.sans.org/webcasts/future-socs-results-2017-survey-security-operations-centers-2-103942/>>. Acesso em: 12 jun. 2024.

CYBRHAWK. **CybrHawk Security Operations Center**. 2019. Disponível em: <<https://cybrhawk.com/security-operations-center/>>. Acesso em: 12 jun. 2024.

FORTINET. **FortiSIEM**. 2021a. Disponível em: <<https://www.fortinet.com/br/products/siem/fortisiem>>. Acesso em: 12 jun. 2024.

FORTINET. **What is SIEM? And why is it a critical security tool?** 2021b. Disponível em: <<https://www.fortinet.com/resources/cyberglossary/what-is-siem>>. Acesso em: 12 jun. 2024.

GARTNER. **What is Security Information and Event Management (SIEM)?** 2021. Disponível em: <<https://www.gartner.com/reviews/market/security-information-event-management>>. Acesso em: 12 jun. 2024.

GERHARDS, R. **The Syslog Protocol**. 2009. Disponível em: <<https://tools.ietf.org/html/rfc5424>>. Acesso em 12 jun. 2024.

IBM. **IBM QRadar SIEM (2018)**. [s.d.]. Disponível em: <<https://www.ibm.com/us-en/marketplace/ibm-qradar-siem>>. Acesso em: 12 jun. 2024.

IBM. **IBM Rolls Out Industry's First Cybersecurity Operations Center on Wheels**. 2018. Disponível em: <[IBM Rolls Out Industry's First Cybersecurity Operations Center on Wheels \(prnewswire.com\)](https://www.prnewswire.com/news-releases/ibm-rolls-out-industry-s-first-cybersecurity-operations-center-on-wheels-301084881.html)>. Acesso em: 12 jun. 2024.

KASPERSKY LAB. **Measuring financial impact of IT security on businesses: IT Security Risks Report**. 2021. Disponível em: <https://www.kaspersky.com/blog/security_risks_report_financial_impact/>. Acesso em: 12 jun. 2024.

KENT, K.; SOUPPAYA, M. Guide to Computer Security Log Management. **NIST**, 2006. Disponível em <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>>. Acesso em: 12 jun. 2024.

LOGRHYTHM. **Security Information and Event Management (SIEM)**. 2021. Disponível em: <<https://logrhythm.com/solutions/security/siem/>>. Acesso em: 12 jun. 2024.

REBACK, G. **O que é SIEM e quais suas principais funcionalidades?** 2020. Disponível em: <<https://seginfo.com.br/2020/09/03/o-que-e-siem-e-quais-suas-principais-funcionalidades/#:~:text=Os%20maiores%20benef%C3%ADcios%20que>>.

%20as,atendimento%20aos%20requisitos%20de%20conformidade>. Acesso em: 12 jun. 2024.

VIELBERTH, M.; PERNUL, G. **A Security Information and Event Management Pattern**. 2018. Disponível em: <<https://www.hillside.net/sugarloafplop/2018/program/papers/GroupA/9.4.pdf>>. Acesso em: 12 jun. 2024.

EMASP